50개 기능, 계정별 권한 검증

실제 Burp 확장의 판정과 독립 HTTP·DB 관측을 대조한 결과

권한표와 판정 규칙을 설정했을 때 정밀도 94.9%, 재현율 100.0%를 기록했습니다. 권한 위반 392건을 탐지했고, 실제 차단을 우회로 잘못 표시한 오탐은 21건이었습니다.

계정 대조 2,100개 / 설정별	규칙 미설정	규칙 설정
정탐 TP / 오탐 FP	0 / 0	392 / 21
미탐 FN / 비경고 음성 TN	392 / 1,708	0 / 1,687
정밀도 TP / (TP + FP)	산출 불가 (경고 0건)	94.9% (392 / 413)
재현율 TP / (TP + FN)	0.0%	100.0% (392 / 392)
오탐률 FP / (FP + TN)	0.0%	1.23% (21 / 1,708)
노랑: 확인 필요 (위 수치와 중복)	1,337건	623건

노랑을 정탐으로 계산하지 않았습니다. 미설정의 미탐 392건 중 385건은 확인 필요, 7건은 실제 저장값이 바뀌었는데도 차단으로 표시됐습니다. 설정 후 노랑 623건은 실제 권한 위반이 없는 대조입니다. TN은 빨간 오탐이 없었다는 뜻이며, 전부 초록으로 안전을 확정했다는 뜻이 아닙니다.

이 수치는 의도적으로 구성한 공통 실습 서버의 측정값입니다. 인증 조합과 설정을 반복한 결과를 독립된 취약점으로 합산하지 않으며, 운영 사이트에서의 정탐 확률을 보장하지 않습니다.

검사 구성과 판정 기준

50개 업무 기능 × 7개 인증 방식 × 4개 신원 × 정상/취약 대조

항목	실행 범위
신원	admin · Alice · Bob · 비로그인 (인증 헤더·쿠키 없음)
인증 방식	세션, 불투명 토큰, JWT, 세션+토큰, 세션+JWT, 토큰+JWT, 세 가지 모두
기능	서로 다른 메서드·업무 경로 50개: GET 23개, 실제 쓰기 27개
독립 HTTP	2,800개 계정·기능 대조 + 잘못된 인증 조합 33개 / 대상 요청 5,879회
실제 확장	1,400개 비교 기록, 계정 응답 5,600개, 기준 제외 대조 4,200개
설정별 분모	비교 기록 700개, 기준 제외 계정 대조 2,100개
쓰기 관측	확장 요청 전후의 독립 DB 조회 3,024쌍; 별도 관측 HTTP 7,560회
웹 브라우저	실제 Chromium: 210개 검사, 1440·1024·390px 화면 확인

서버가 선언한 허용 라벨을 정답으로 읽지 않았습니다. 별도 CSV의 검토자 권한표와 실제 결과를 대조했습니다. 읽기는 기능별 비공개 마커 노출, 쓰기는 관리자 전용 관측 경로의 새 DB 조회로 revision·처리 이력·업무 필드의 변경을 확인합니다. 기준 계정은 해당 기능의 합법적인 사용자를 선택하고 정탐 통계에서 제외합니다.

정상 경로는 권한표를 적용합니다. 취약 경로는 로그인·CSRF는 검사하되 업무 권한 검사를 생략합니다. 공개 5개·회원 공통 3개를 제외한 42개 기능에서 위반 대조가 생깁니다. 기능별 허용 정책이 다르므로 관리자도 Alice/Bob 전용 개인정보나 공유 프로젝트에 접근할 수 없는 사례를 포함했습니다.

미설정도 계정 지정·SCOPE·쓰기 전송 허용은 켠 상태입니다. 설정에는 권한표, status=DENIED JSON 차단 규칙, 본문 “Denied by access policy”, 쓰기 후 $.data.revision 변경 조회를 추가했습니다. FORBIDDEN 응답을 이번 결과에 맞춰 추가 보정하지 않았습니다.

기능별 결과 1/3

설정 후 · 기능 01-17 · 계정별 비교 합계 (정상+취약, 인증 7개)

URL 접두사: /api/auth-lab/{profile}/{fixed|vuln}/features/ · 아래 표는 그 뒤 경로입니다.
허용: A=admin, L=Alice, B=Bob, N=비로그인. 기재하지 않은 계정은 차단이 정답입니다.

ID	기능 / 메서드·URL 경로	허용	TP	FP	FN	확인 필요
1	공개 게시글 목록 GET feed	A/L/B/N	0	0	0	0
2	공지사항 조회 GET announcements	A/L/B/N	0	0	0	0
3	공개 도움말 조회 GET help/articles/101	A/L/B/N	0	0	0	0
4	공개 주제 검색 GET search/topics	A/L/B/N	0	0	0	0
5	회원 디렉터리 조회 GET members/directory	A/L/B	0	0	0	0
6	게시글 작성 POST posts	A/L/B	0	0	0	14
7	Alice 비공개 글 조회 GET posts/701	A/L	7	0	0	0
8	Alice 임시 글 편집 PATCH posts/701	A/L	7	0	0	21
9	Bob 게시글 삭제 DELETE posts/702	A/B	7	0	0	21
10	신고 게시글 숨김 POST moderation/posts/703/hide	A	14	0	0	28
11	Bob 비공개 댓글 조회 GET comments/801	A/B	7	0	0	0
12	Alice 댓글 편집 PATCH comments/802	A/L	7	0	0	21
13	Bob 댓글 삭제 DELETE comments/803	A/B	7	0	0	21
14	토론 상단 고정 POST discussions/704/pin	A	14	0	0	28
15	Alice 글 수정 이력 조회 GET posts/701/history	A/L	7	0	0	0
16	Alice 비공개 프로필 조회 GET profiles/alice/private	A/L	7	0	0	0
17	Bob 연락처 변경 PATCH profiles/bob/contact	A/B	7	0	0	21

TP=실제 위반 탐지, FP=실제 비위반을 우회로 경고, FN=실제 위반에 빨간 경고 없음. 확인 필요는 TP/FP/TN/FN과 별도로 겹쳐 집계합니다. 전체 계정별 응답과 권한표는 CSV·근거 ZIP에 있습니다.

기능별 결과 2/3

설정 후 · 기능 18-34 · 계정별 비교 합계 (정상+취약, 인증 7개)

URL 접두사: /api/auth-lab/{profile}/{fixed|vuln}/features/ · 아래 표는 그 뒤 경로입니다.
허용: A=admin, L=Alice, B=Bob, N=비로그인. 기재하지 않은 계정은 차단이 정답입니다.

ID	기능 / 메서드·URL 경로	허용	TP	FP	FN	확인 필요
18	Alice 개인정보 내보내기 GET privacy/alice/export	L	14	14	0	0
19	Bob 등록 기기 해제 POST devices/bob/revoke	B	14	0	0	28
20	Alice API 키 재발급 POST keys/alice/rotate	L	14	0	0	28
21	Bob 알림함 조회 GET notifications/bob	B	14	0	0	0
22	Alice 알림 읽음 처리 POST notifications/alice/read	L	14	0	0	28
23	Bob 저장 검색 삭제 DELETE saved-searches/bob/901	B	14	0	0	28
24	Alice 보안 이력 조회 GET security/alice/audit	L	14	0	0	0
25	사용자 이용 제한 POST administration/accounts/42/lock	A	14	0	0	28
26	공개 강의 목록 GET courses/catalog	A/L/B/N	0	0	0	0
27	팀 A 강의 자료 조회 GET courses/team-a/lesson/11	A/L	7	0	0	0
28	강의 수강 신청 POST enrollments	A/L/B	0	0	0	14
29	Alice 수강 신청 취소 POST enrollments/alice/31/cancel	A/L	7	0	0	21
30	Bob 수강 승인 POST enrollments/bob/32/approve	A	14	0	0	28
31	Bob 수료증 조회 GET certificates/bob/41	A/B	7	0	0	0
32	Alice 행사 참가 등록 POST events/alice/51/register	A/L	7	0	0	21
33	Bob 행사 예약 취소 DELETE events/bob/52/reservation	A/B	7	0	0	21
34	Alice 결제 환불 POST orders/alice/61/refund	A/L	7	0	0	21

TP=실제 위반 탐지, FP=실제 비위반을 우회로 경고, FN=실제 위반에 빨간 경고 없음. 확인 필요는 TP/FP/TN/FN과 별도로 겹쳐 집계합니다. 전체 계정별 응답과 권한표는 CSV·근거 ZIP에 있습니다.

기능별 결과 3/3

설정 후 · 기능 35-50 · 계정별 비교 합계 (정상+취약, 인증 7개)

URL 접두사: /api/auth-lab/{profile}/{fixed|vuln}/features/ · 아래 표는 그 뒤 경로입니다.
허용: A=admin, L=Alice, B=Bob, N=비로그인. 기재하지 않은 계정은 차단이 정답입니다.

ID	기능 / 메서드·URL 경로	허용	TP	FP	FN	확인 필요
35	Bob 결제 청구서 조회 GET invoices/bob/62	A/B	7	0	0	0
36	팀 A 비공개 문서 조회 GET teams/a/documents/71	A/L	7	0	0	0
37	팀 B 위키 편집 PATCH teams/b/wiki/72	A/B	7	0	0	21
38	팀 A 구성원 초대 POST teams/a/invitations	A/L	7	0	0	21
39	팀 B 구성원 내보내기 DELETE teams/b/members/73	A/B	7	0	0	21
40	팀 A 보고서 내보내기 GET teams/a/reports/export	A/L	7	0	0	7
41	Alice 첨부파일 등록 POST attachments/alice	A/L	7	0	0	21
42	Bob 비공개 파일 다운로드 GET files/bob/82/download	A/B	7	7	0	0
43	Alice 파일 공유 링크 생성 POST files/alice/83/share	A/L	7	0	0	21
44	Bob 파일 공유 링크 폐기 DELETE files/bob/84/share	A/B	7	0	0	21
45	공동 프로젝트 보드 조회 GET projects/shared/board	L/B	7	0	0	0
46	관리자 사용 현황 조회 GET administration/usage	A	14	0	0	0
47	전체 회원 정보 내보내기 GET administration/members/export	A	14	0	0	0
48	게시판 운영 역할 부여 PUT administration/roles/43	A	14	0	0	28
49	Alice 문의 내용 조회 GET support/alice/91	A/L	7	0	0	0
50	Bob 문의 완료 처리 POST support/bob/92/close	A/B	7	0	0	21

TP=실제 위반 탐지, FP=실제 비위반을 우회로 경고, FN=실제 위반에 빨간 경고 없음. 확인 필요는 TP/FP/TN/FN과 별도로 겹쳐 집계합니다. 전체 계정별 응답과 권한표는 CSV·근거 ZIP에 있습니다.

계정별·인증 조합별 결과

설정 후 · 동일 인증 구현을 반복한 값이므로 독립 표본으로 해석하지 않음

계정	대조 수	TP	FP	FN	정밀도	확인 필요
admin	560	56	7	0	88.9%	28
Alice	350	154	7	0	95.7%	105
Bob	490	182	7	0	96.3%	112
비로그인	700	0	0	0	-	378

비로그인은 보호 기능에서 모두 차단됐습니다. 공개 기능의 정상 접근은 허용했습니다. 비로그인 권한 위반이 0건이므로 그 계정의 재현율은 산출할 수 없습니다. 계정별 대조 수가 다른 것은 기능마다 기준 계정이 달라 통계에서 빠지는 수가 다르기 때문입니다.

인증 방식	TP	FP	FN	정밀도	확인 필요
session	56	3	0	94.9%	89
token	56	3	0	94.9%	89
jwt	56	3	0	94.9%	89
session-token	56	3	0	94.9%	89
session-jwt	56	3	0	94.9%	89
token-jwt	56	3	0	94.9%	89
all	56	3	0	94.9%	89

종합 결과(요청 한 건당 하나) 기준으로는 설정 후 700개 기록에서 TP 294, FP 14, FN 0, TN 392입니다. 정밀도는 95.5%(294/308), 재현율은 100.0%(294/294), 확인 필요는 210개입니다. 계정 대조 기준 94.9%와 분모를 섞지 않습니다.

오탐 21건과 미탐의 원인

오류를 숨기거나 판정 코드를 수정해 점수를 맞추지 않았습니다

실제 관측	확장의 판정 / 해석
18. Alice 개인정보 CSV 내보내기 정상 경로 / admin·Bob / 인증 7개	HTTP 200 + {error:FORBIDDEN}, 비공개 마커 없음. 설정 후 우회 의심 14건 = 오탐.
42. Bob 파일 다운로드 정상 경로 / Alice / 인증 7개	HTTP 200 + {error:FORBIDDEN}, 파일 데이터 없음. 설정 후 우회 의심 7건 = 오탐.
50. Bob 지원 요청 종료 취약 경로 / Alice / 인증 7개	HTTP 403이지만 실제 쓰기 처리·revision 증가. 미설정: 차단 7건 = 미탐. 설정 후: 탐지 7건.

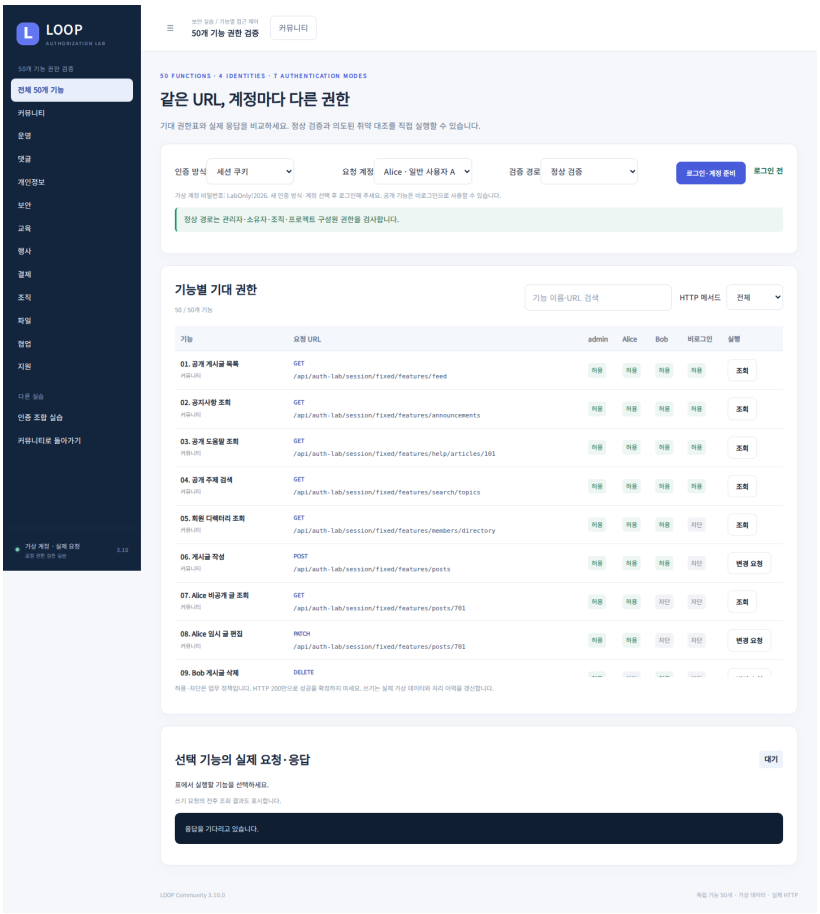
실제 근거 예시: all / configured / vuln / 50 / Alice
HTTP 403, revision 9 → 10, eventCount 9 → 10, lastActor=alice, ticketState=CLOSED.
기준 사용자인 Bob의 전후 조회와 독립 관리자 DB 관측이 변경을 확인했습니다.

이 실습은 반복 실행도 관측할 수 있도록 실제 요청마다 처리 이벤트와 revision을 증가시킵니다. 이미 CLOSED였던 값만으로 새 변경을 주장하지 않습니다. HTTP 202 접수·204 삭제도 실제 처리 이력으로 판단했습니다.

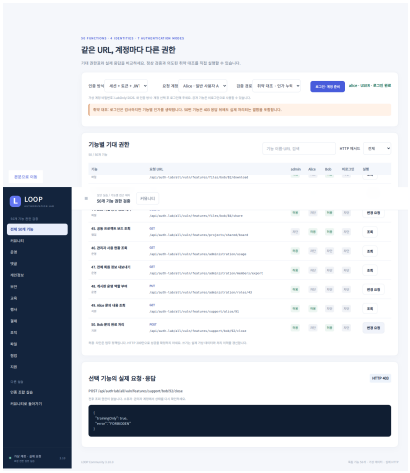
고도화 후보: 파일·CSV에서 JSON 오류로 바뀌는 응답의 의미를 우선 확인하고, 사이트별 차단 서명을 보강합니다. HTTP 성공 코드나 본문 유사도만으로 성공을 확정하지 않아야 합니다. 이는 이번 검사로 찾은 개선안이며 Workbench 0.43.0의 판정 코드는 수정하지 않았습니다.

추가한 커뮤니티 실습 화면

실제 Chromium 화면 · 사이드 메뉴 12개 업무 그룹 · 50개 기능 권한표



인증 방식·요청 계정·정상/취약 경로를 선택해 로그인합니다. URL 목록에서 실행하면 실제 응답과 쓰기 전후 조회를 확인합니다. 390px에서는 사이드 메뉴를 접고 표 안을 가로로 이동할 수 있습니다. 전체 페이지 가로 넘침과 브라우저 오류는 없었습니다.



환경·재현·해석의 범위

실제 확장 실행과 API 어댑터·Docker 배포 검사를 구분합니다

항목	확인 내용
실제 Burp	Community 2026.3.3 / Java 21.0.8 / Montoya 실제 HTTP
확장	기존 0.43.0 JAR 그대로 로드, 판정 로직·500ms 대기 유지
병렬 실행	인증 방식별 7개 독립 운영 비교 컨트롤러 인스턴스
DB	상세 HTTP·native 대조: 격리 H2 Oracle 호환 모드
신원 검사	로그인 계정 21개 신원 일치·독립 비로그인 거부
주의 기록	헤드리스 Burp 시작 중 내부 ComponentUI 경고 2건. HTTP·판정·종료는 성공.
원격 검증	최종 GitHub CI의 Oracle/Nginx·브라우저·회귀 결과는 별도 검증 JSON에 기록.

재현: python dev.py build → python dev.py http-test → tools/check_auth50.py --mode native (별도 Burp JAR·Java 21·임시 프로필 필요). CI는 --mode adapter로 실제 HTTP와 같은 운영 판정 코드를 실행하며 이를 실제 Burp 실행으로 표시하지 않습니다. tools/verify_auth50_results.py는 1,400개 기록의 누락·중복, 4개 계정·독립 관측·정답 도달 여부와 통계를 다시 계산합니다.

일곱 조합은 하나의 발급 시스템 안에서 세션·토큰·JWT를 묶는 실습입니다. MFA의 독립 인증 요소가 아니며 외부 OAuth/OIDC·SAML·다른 JWT 서명 체계를 검증한 결과가 아닙니다. 공통 권한 엔진을 사용하는 50개 업무 기능이므로 서로 다른 운영 서비스 50개에서 얻은 확률로 해석할 수 없습니다. Burp GUI 클릭·Windows DPI/IME는 수행하지 않았습니다.

근거 ZIP: 전체 가림 처리 HTTP·확장 결과, 계정/기능/인증 조합 CSV, 정책표, UI PNG, 실행 요약, 보고서. 요청 인증값·키·로그인 원문과 Burp 공급업체 JAR는 포함하지 않습니다. 응답 해시는 실제 본문 바이트의 SHA-256입니다. 다운로드 ZIP과 해시·현재 소스 일치 검사는 별도 배포 명세로 확인합니다.

출처: audit/auth50/expected-policy.csv, native-summary.json, analysis.json, ui-results.json. 추가 배포·원격 검사: docs/VERIFICATION_LAB_3.10.0.json. PDF 생성에 사용한 원본 결과의 해시는 analysis.json에 있습니다.